

Encuesta HyVAW-NIS2 sobre Análisis Híbrido de Vulnerabilidades y Resiliencia

0. Datos generales de la organización

0.1. Sector principal de actividad (según clasificación NIS2):

- Energía
- Transporte
- Banca y servicios financieros
- Sanidad
- Agua potable y aguas residuales
- Infraestructuras digitales (operadores de centros de datos, DNS, etc.)
- Administración pública
- Proveedor de servicios digitales (cloud, marketplaces, etc.)
- Otro (especificar): _____

0.2. Tamaño de la organización:

- Micro / pequeña (menos de 50 empleados)
- Mediana (50–249 empleados)
- Grande (250–4.999 empleados)
- Muy grande (5.000 o más empleados)

0.3. Rol de quien responde:

- CISO / Director de Seguridad de la Información
- Responsable de Continuidad / Resiliencia
- Responsable de Sistemas / Infraestructuras
- Responsable de Riesgos / Cumplimiento
- Otro (especificar): _____

1. Inventario de activos y modelado de sistemas

1.1. ¿Dispone la organización de un inventario formalmente aprobado de activos críticos (sistemas, aplicaciones, infraestructuras, procesos de negocio)?[web:23][web:36]

- Sí, actualizado y revisado al menos una vez al año
- Sí, pero con actualizaciones ad hoc y no sistemáticas
- Parcial (solo para algunos sistemas o proyectos)
- No, o no formalmente documentado
- No sabe / No responde

1.2. ¿En qué medida se encuentran identificados y documentados los componentes distribuidos (on-prem, nube, OT, IoT, proveedores externos) relevantes para los servicios esenciales?[web:3][web:16][web:32]

- Completamente identificados y documentados
- Mayoritariamente identificados, con algunas lagunas conocidas

- Solo identificados a nivel de alto nivel (servicios, no componentes)
- De forma fragmentaria, por proyectos o áreas
- No se dispone de identificación sistemática

1.3. ¿La organización elabora modelos de amenazas (threat models) formales para sus sistemas críticos?
[web:3][web:16][web:31]

- Sí, para todos los sistemas críticos
- Sí, para algunos proyectos o cambios significativos
- Solo de manera informal (diagramas, sesiones, pero sin metodología)
- No se realizan modelos de amenazas
- No sabe / No responde

1.4. Si realiza modelos de amenazas, ¿qué metodologías o marcos utiliza habitualmente? (seleccione todas las que apliquen)[web:3][web:29][web:36]

- STRIDE u otra metodología basada en categorías de amenazas
- CVSS u otra métrica cuantitativa de impacto / probabilidad
- Árboles de ataque / ADT
- Metodologías híbridas tipo HyVAW o similares
- Otra (especificar): _____
- No aplica / No se realizan modelos de amenazas

1.5. En una escala de 1 a 5, ¿cómo valoraría la **cobertura de activos** de los modelos de amenazas existentes (1 = muy baja, 5 = muy alta)?

- 1
- 2
- 3
- 4
- 5
- No aplica / No se realizan modelos de amenazas

2. Flujo híbrido de análisis de vulnerabilidades (HyVAW o equivalente)

2.1. En la práctica, ¿qué tipos de análisis de vulnerabilidades se utilizan de forma habitual para sistemas críticos?[web:3][web:8][web:19]

- Análisis estático (SAST, revisión de código, análisis de dependencias)
- Análisis dinámico (DAST, pruebas de caja negra, fuzzing)
- Escáneres de infraestructura / configuración (red, cloud, OT)
- Pentesting manual interno
- Pentesting manual externo / Red teaming
- Análisis híbrido orquestado (combinación sistemática de varios anteriores)
- Otros (especificar): _____

2.2. ¿Existe un **flujo de trabajo definido** que combine de forma sistemática estos tipos de análisis (es decir, un enfoque híbrido documentado)?[web:3][web:8][web:24]

- Sí, formalmente definido, documentado y aplicado en toda la organización
- Sí, definido pero aplicado solo en algunos ámbitos o proyectos
- Parcial: existe coordinación informal entre equipos y herramientas
- No, cada tipo de análisis se realiza de forma separada
- No se realizan análisis de vulnerabilidades de forma regular

2.3. ¿El flujo de análisis híbrido incorpora al menos tres de las siguientes fases: modelado de amenazas, análisis estático, análisis dinámico, pruebas manuales, correlación de hallazgos, priorización y remediación?[web:3][web:8][web:24]

- Sí, todas las fases mencionadas
- Sí, la mayoría (cuatro o cinco fases)
- Solo algunas (dos o tres fases)
- Una fase dominante, sin integración (por ejemplo, solo escáneres)
- No se dispone de flujo estructurado

2.4. ¿Con qué frecuencia se ejecutan los análisis híbridos, o en su defecto, la combinación de análisis que más se le parezca?[web:19][web:23]

- Continuamente (CI/CD, pipelines automatizados, escaneo continuo)
- Periódicamente (al menos trimestral)
- Periódicamente (al menos anual)
- Solo en grandes cambios de sistema o proyectos
- De forma puntal, sin planificación establecida
- No se realizan

2.5. En una escala de 1 a 5, ¿cuánta confianza tiene en que su enfoque actual detecta las vulnerabilidades más críticas antes de que se conviertan en incidentes?[web:8][web:19][web:32]

- 1 (muy poca)
- 2
- 3
- 4
- 5 (muy alta)
- No sabe / No responde

3. Métricas de calidad del análisis (falsos positivos, cobertura, etc.)

3.1. ¿La organización mide de manera sistemática la **tasa de falsos positivos** generados por sus herramientas de análisis de vulnerabilidades?[web:8][web:19][web:24]

- Sí, de forma cuantitativa y periódica
- Sí, pero solo para algunos entornos o herramientas
- Solo de forma cualitativa (sensaciones del equipo, sin datos consolidados)
- No, nunca se ha medido
- No sabe / No responde

3.2. En caso afirmativo, ¿qué porcentaje aproximado de hallazgos críticos se considera que son falsos positivos?

- Menos del 10 %
- Entre el 10 % y el 25 %
- Entre el 25 % y el 50 %
- Más del 50 %
- No se dispone de estimación
- No aplica / No medido

3.3. ¿Se mide la **cobertura de análisis** respecto al inventario de activos y al modelo de sistema (por ejemplo, porcentaje de componentes / rutas de ejecución cubiertos)?[web:3][web:8][web:24]

- Sí, mediante indicadores formales revisados regularmente
- Sí, pero solo en algunos proyectos o sistemas
- Solo de modo aproximado, sin métricas claras
- No, la cobertura no se mide
- No sabe / No responde

3.4. ¿Qué clase de indicadores utiliza para evaluar la eficacia del flujo híbrido de análisis (HyVAW o equivalente)?[web:3][web:19][web:36]

- Número de vulnerabilidades descubiertas por ciclo
- Severidad promedio / distribución de severidades
- Reducción de falsos positivos en comparación con enfoques anteriores
- Incremento de vulnerabilidades críticas detectadas
- Comparación entre hallazgos estáticos, dinámicos y manuales
- Otros (especificar): _____
- No se utilizan indicadores específicos

3.5. ¿Se correlacionan los incidentes reales con vulnerabilidades previamente identificadas para evaluar el riesgo residual?[web:23][web:32][web:34]

- Sí, de forma estructurada, con análisis post-incidente formal
- Sí, pero solo en incidentes de alto impacto
- De forma ocasional e informal
- No, no se realiza dicha correlación
- No sabe / No responde

4. Gestión de vulnerabilidades, tiempos y priorización

4.1. ¿Existe un proceso formal de gestión de vulnerabilidades (registro, clasificación, priorización, remediación, cierre) alineado con NIS2 u otros marcos de referencia?[web:23][web:36]

- Sí, formalmente definido, documentado y auditado
- Sí, definido pero no completamente implantado
- Existe un proceso, pero está fragmentado por áreas o tecnologías
- Se gestiona de manera reactiva y ad hoc
- No existe un proceso definido

4.2. ¿La organización mide el **tiempo medio de remediación (TTR)** de vulnerabilidades por severidad?[web:19][web:23][web:32]

- Sí, para todas las vulnerabilidades críticas, altas y medias
- Sí, solo para vulnerabilidades críticas y altas
- Sí, pero los datos no se consolidan ni revisan regularmente
- No se mide el tiempo de remediación
- No sabe / No responde

4.3. Aproximadamente, ¿cuál es el tiempo medio de remediación de vulnerabilidades críticas en sistemas esenciales?

- Menos de 7 días
- Entre 7 y 30 días
- Entre 30 y 90 días
- Más de 90 días
- No se dispone de estimación
- No aplica / No hay vulnerabilidades críticas (o eso nos gusta pensar)

4.4. ¿Qué criterios se utilizan para priorizar la remediación de vulnerabilidades?[web:3][web:12][web:36]

- Solo la severidad técnica (por ejemplo, CVSS)
- Severidad técnica y criticidad del activo
- Severidad técnica, criticidad del activo y exposición real (expuesto a Internet, segmentación, etc.)
- Además, alineación con escenarios de amenaza concretos (modelos tipo HyVAW)
- No existe un esquema de priorización definido

4.5. ¿Se revisan periódicamente las excepciones y aceptaciones de riesgo vinculadas a vulnerabilidades no corregidas?[web:33][web:36]

- Sí, con periodicidad definida y aprobación de la alta dirección
- Sí, pero con periodicidad irregular
- Solo en incidentes o auditorías
- No se revisan
- No sabe / No responde

5. Integración con requisitos NIS2 / ENISA

5.1. ¿La organización ha realizado un análisis formal de brecha (gap analysis) respecto a NIS2 y su reglamento de ejecución, incluyendo gestión de vulnerabilidades y análisis de riesgos?[web:23][web:36]

- Sí, con apoyo de expertos internos y/o externos
- Sí, pero limitado a algunos dominios (incidentes, continuidad, etc.)
- Está previsto, pero aún no realizado
- No se ha realizado ni está previsto
- No sabe / No responde

5.2. ¿Las evidencias generadas por el flujo de análisis de vulnerabilidades (HyVAW o equivalente) se utilizan explícitamente para demostrar cumplimiento de NIS2 ante auditores o autoridades?[web:23][web:36]

- Sí, de forma sistemática como parte del dossier de cumplimiento
- Sí, pero de forma parcial y no siempre documentada
- No todavía, pero está en planificación
- No, se tratan como un proceso puramente técnico
- No sabe / No responde

5.3. ¿Qué áreas de la guía técnica de ENISA sobre medidas de gestión de riesgos considera que están mejor cubiertas por sus prácticas actuales de análisis de vulnerabilidades?[web:23][web:36]

- Gestión de activos y arquitectura
- Gestión de vulnerabilidades y parches
- Gestión de identidades y accesos
- Seguridad de la cadena de suministro
- Monitorización y detección de incidentes
- Continuidad de negocio y recuperación
- No se ha analizado explícitamente

5.4. ¿Se ha asignado responsabilidad clara, a nivel de alta dirección, sobre la aceptación de riesgos derivados de vulnerabilidades no mitigadas, tal y como exige NIS2?[web:23][web:33][web:36]

- Sí, formalmente documentada y aplicada
- Sí, pero en la práctica se trata de decisiones técnicas
- Parcialmente, según el tipo de riesgo
- No, no existe asignación clara
- No sabe / No responde

6. Resultados operativos y resiliencia

6.1. ¿Dispone la organización de indicadores que relacionen vulnerabilidades con incidentes reales (por ejemplo, “incidentes derivados de vulnerabilidades previamente identificadas”)?[web:32][web:34]

- Sí, de forma cuantitativa y revisada periódicamente
- Sí, pero solo para algunos tipos de incidentes
- De forma cualitativa, en análisis post-incidente
- No se realiza esa relación
- No sabe / No responde

6.2. A lo largo de los últimos 12 meses, ¿ha sufrido la organización incidentes significativos (interrupciones relevantes, robo de datos, fraude) derivados de vulnerabilidades conocidas y no mitigadas a tiempo?[web:31][web:32][web:34]

- Sí, más de un incidente significativo
- Sí, un incidente significativo
- Solo incidentes menores o contenidos

- No, o no se tiene constancia
- Prefiere no responder

6.3. ¿Se utilizan los resultados del análisis híbrido de vulnerabilidades para alimentar ejercicios de simulación, ciber-ejercicios o pruebas de estrés (stress tests) de ciber-resiliencia? [web:23][web:31][web:36]

- Sí, de forma estructurada y recurrente
- Sí, pero solo de forma esporádica
- No todavía, pero está previsto
- No se utilizan en este contexto
- No sabe / No responde

6.4. En una escala de 1 a 5, ¿cómo valoraría la madurez global de su organización en gestión híbrida de vulnerabilidades y resiliencia frente a las exigencias de NIS2? [web:23][web:32][web:36]

- 1 (incipiente)
- 2 (básica)
- 3 (intermedia)
- 4 (avanzada)
- 5 (líder / referencia)
- No sabe / No responde

7. Inversión, beneficios y retorno (ROI) de HyVAW

7.1. ¿Dispone la organización de un presupuesto específico para actividades de análisis de vulnerabilidades (herramientas, personal, servicios externos)? [web:23][web:36]

- Sí, presupuesto claramente asignado y diferenciado
- Sí, pero integrado en otras partidas de seguridad o TI
- No, se financia de manera ad hoc
- No se tiene visibilidad sobre este aspecto

7.2. ¿Se han cuantificado los beneficios (reducción de incidentes, evitación de pérdidas, mejora del cumplimiento) asociados al análisis híbrido de vulnerabilidades? [web:19][web:23][web:32]

- Sí, con métricas financieras y de riesgo
- Sí, pero solo a nivel cualitativo
- Está previsto, pero aún no realizado
- No se han cuantificado
- No sabe / No responde

7.3. ¿Con qué indicadores se evalúa internamente el retorno de la inversión (ROI) de las iniciativas de análisis de vulnerabilidades? [web:19][web:32][web:34]

- Reducción del número de incidentes
- Reducción de la severidad media de los incidentes
- Cumplimiento regulatorio y evitación de sanciones
- Mejora de disponibilidad / continuidad de servicios

- Ahorro de tiempo del equipo técnico (menos falsos positivos)
- No se evalúa el ROI de forma específica

7.4. Si tuviera que justificar ante el Consejo de Administración un incremento del 20 % en el presupuesto de análisis híbrido de vulnerabilidades, ¿con qué argumentos se sentiría más cómodo?

- Reducción demostrable del riesgo operativo
- Cumplimiento estricto de NIS2 y estándares europeos
- Alineamiento con buenas prácticas del sector
- Protección de la reputación y confianza de clientes
- Otros (especificar): _____

8. Mirando al futuro (y al espejo)

8.1. ¿En qué horizonte temporal considera realista disponer de un flujo de análisis de vulnerabilidades plenamente híbrido y alineado con HyVAW para sus servicios esenciales? [web:3][web:16][web:23]

- Menos de 12 meses
- Entre 1 y 2 años
- Entre 2 y 3 años
- Más de 3 años
- Ya se dispone
- No está previsto

8.2. ¿Qué barreras principales percibe para avanzar en este sentido?

- Falta de recursos económicos
- Falta de personal especializado
- Complejidad tecnológica / legacy
- Dificultad para coordinar proveedores y terceros
- Falta de prioridad en la dirección
- Otros (especificar): _____

8.3. Si pudiera “pedir un deseo” razonable a las autoridades o a ENISA para facilitar la implantación de HyVAW y similares en su sector, ¿qué pediría?

- Guías sectoriales más específicas
- Esquemas de certificación y reconocimiento
- Ayudas económicas / incentivos
- Plataformas compartidas de análisis e intercambio de información
- Menos papeleo y más claridad (sí, también cuenta)
- Otros (especificar): _____

Gracias por su tiempo, por su paciencia y por contribuir a que las vulnerabilidades dejen de ser una sorpresa y pasen a ser, como debe ser, un asunto de gestión ordinaria.